The Neutral Vault — MVP Specification

Oct 22, 2026 · @haley

Overview and scope

The Neutral Vault is a working demo of how banks, telcos and e-wallets could share mule-account intelligence while the host of the system can neither read the data nor change who is allowed to see it. The MVP is done when the five-minute demo runs end to end on synthetic data, three times in a row.

Problem. Scam money moves through mule accounts. Malaysia's National Scam Response Centre handled 66,997 calls in 2023 and disrupted 59,684 suspected mule accounts (BNM Annual Report 2023, reported March 2024). Institutions that want to share what they know face one party that would see everything.

Positioning. Bank Negara Malaysia, PayNet and the banks already run the National Fraud Portal (launched 20 August 2024) for fund tracing and intelligence sharing. The Neutral Vault does not claim the problem is unaddressed. It shows how this kind of sharing could be operator-blind, policy-gated and member-governed. We could not confirm whether telcos and e-wallets take part in the portal, so the pitch makes no claim either way.

Constraint. Under the Financial Services Act 2013 (s.133), banks owe customers a duty of secrecy with narrow exceptions, such as enforcement requests and suspected offences. This reading comes from a 2016 article and needs a lawyer's or lecturer's check before it appears on a slide.

Real vs simulated

- Real: BYOiD login, encryption in the browser, role-gated decryption, approvals and governance through TideCloak.
- Simulated: all organisations, analysts, accounts and reports. Use synthetic data only, never real customer data.

Non-goals

- Not decentralised finance: no blockchain, no tokens, no movement of money.
- No fund tracing, account freezing, machine-learning scoring or integration with the National Fraud Portal.
- No production compliance claims.
- Private set intersection is roadmap only.

Actors, organisations and roles

Four synthetic member organisations and one adversary, the operator, who hosts the system but is never trusted with data or authority.

Actor	Type	Role in the app	Can	Cannot
Bank A	Member (reporter)	`vault-analyst`, `vault-approver`, `vault-admin`	File reports, look up accounts, approve disclosures, vote	Approve its own disclosure request
Bank B	Member (checker)	`vault-analyst`, `vault-approver`, `vault-admin`	Look up accounts, request evidence, vote	Read evidence without two approvals
Telco C	Member (third-party approver)	`vault-analyst`, `vault-approver`, `vault-admin`	Look up, approve as an independent organisation, vote	Approve a request it made itself
E-wallet D	Applicant, joins live	none until admitted	Nothing before the vote passes	Log in as a member before admission
Operator	Adversary (hosts server and database)	none	Dump the database, read server logs, run the app	Read plaintext, mint access, change roles alone

Role names. Three realm roles carry authority: `vault-analyst` (report and look up), `vault-approver` (approve disclosures) and `vault-admin` (vote on governance). Each user also belongs to exactly one organisation. How the organisation reaches the token (group or user attribute) is spike S3.

Distinct-organisation rule. A disclosure of evidence needs two approvals from two different organisations. One must be the reporting organisation. The other must be neither the requester's nor the reporter's organisation. No user approves a request their own organisation made, and no user approves twice.

Quorum rule. Governance changes need a strict majority of active member organisations. With three active members, two votes pass a proposal.

Features and acceptance criteria

Nine features, ranked so the demo still works if the last ones slip. Must-haves alone already show the operator-blind claim.

ID	Feature	Priority	Acceptance criteria
F1	BYOiD login and role gating	Must	Analysts from each of the three member organisations can sign in. An API call with no token returns 401. A valid token without the needed role returns 403.
F2	Submit an encrypted report	Must	The stored row holds no plaintext account identifier, reason code or evidence. An authorised member's browser decrypts it correctly.
F3	Tier-1 lookup	Must	A Bank B analyst enters an account and sees hit or no match. A hit shows reason code, reporting organisation and date, never the evidence. Result appears within 2 seconds on the demo machine.
F4	Operator view	Must	A page shows the raw tables and server log as the operator sees them: ciphertext, keyed hashes, timestamps and row counts only.
F5	Rogue-admin attempt blocked	Must	Assigning a vault role to the operator's own account has no effect without a quorum. The attempt and its outcome are visible on screen.
F6	Tier-2 disclosure	Should	A request needs a case reference and two approvals from two distinct organisations (see Actors). Self-approval and double approval are rejected. After approval the requester can decrypt the evidence for 30 minutes, then decryption fails. A denial is recorded.
F7	Audit log	Should	Every login failure, lookup, request, approval, denial and vote shows actor, organisation, time and result. Entries cannot be edited from the UI.

ID	Feature	Priority	Acceptance criteria
F8	Governance vote	Could	A proposal to admit E-wallet D passes with two of three member votes. Before it passes D cannot log in as a member. After it passes D's analysts can file and look up.
F9	Tamper-evident audit	Could	Each audit entry stores the hash of the previous one. A check page flags any broken link.

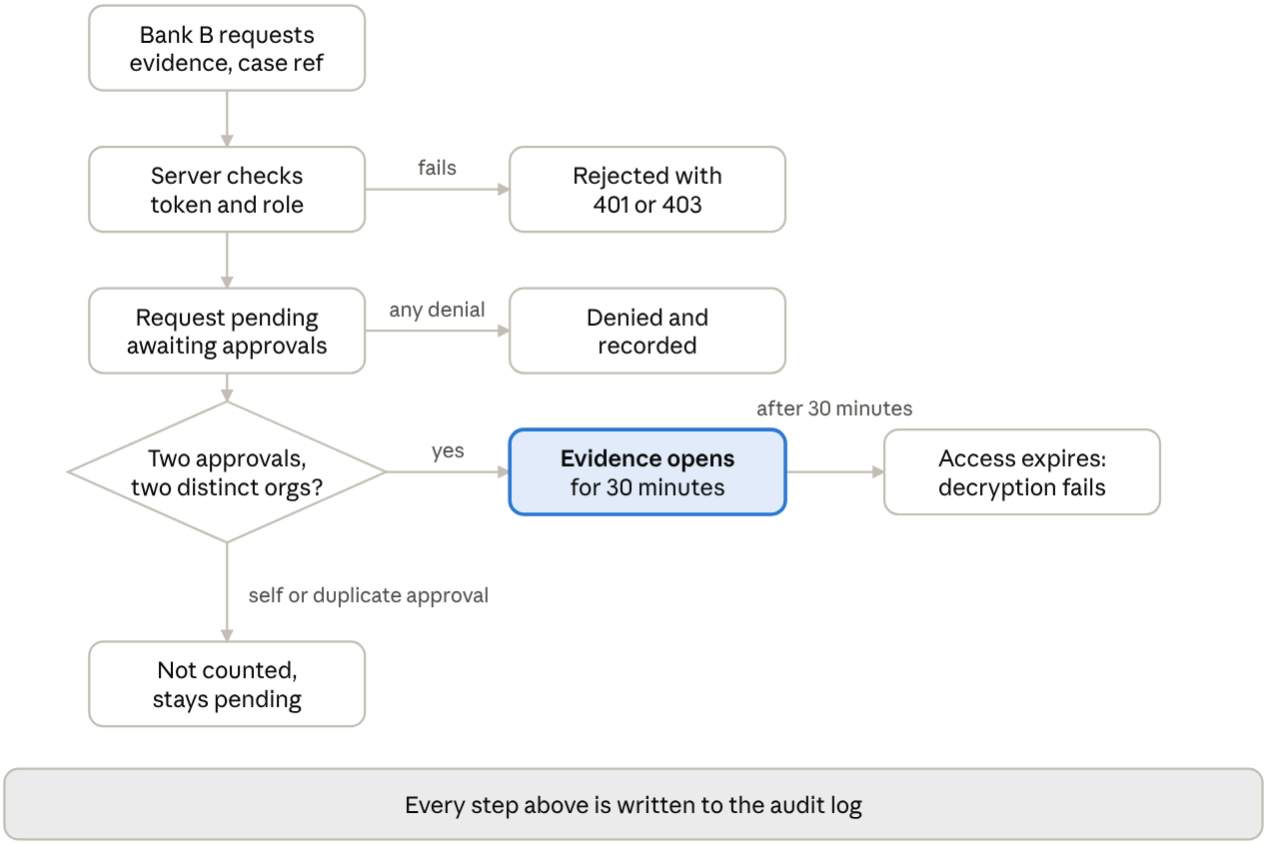
Out of scope for the MVP: account freezing, notifications, file attachments beyond text, multiple evidence versions, and any bulk import.

User flows

Six flows cover the whole MVP. Only the evidence disclosure branches, so it is drawn.

1. **Sign in.** The user signs in with BYOiD. The server verifies the token and reads the role and organisation. The browser decrypts the index key into memory only.
2. **File a report.** The analyst enters an identifier, reason code and evidence. The browser hashes the identifier, encrypts the tier-1 data and evidence, and posts them. An audit event is written.
3. **Look up.** The analyst enters an identifier. The browser hashes it, the server returns matching tier-1 ciphertext, and the browser decrypts it to show a hit or no match.
4. **Disclose evidence (tier 2).** Drawn below.
5. **Govern.** A member admin proposes admitting an organisation. Admins vote. At a strict majority the organisation becomes active, through TideCloak's quorum if spike S5 passes, otherwise through a labelled app-level vote.
6. **Audit.** Every action above creates an event on the audit page.

Evidence opens only after two approvals from two distinct organisations



disclosure approval flow · 1 decision, 4 outcomes

The request is checked first, then waits for two approvals. A denial ends it. Approvals from the requester's own organisation, or twice from one user, are not counted. Once evidence opens, access lasts 30 minutes.

Data model and what the operator sees

The operator's database holds ciphertext, keyed hashes and metadata only. Anything sensitive is encrypted in the member's browser before it is sent.

Entity	Fields	Stored as
Organisation	id, name, type (bank, telco, e-wallet), status (active, pending)	Plaintext
Member	TideCloak user id, organisation id, roles	Plaintext mapping; credentials live in TideCloak

Entity	Fields	Stored as
Report	id, `indexHash`, `reportingOrgId`, `tier1Ciphertext`, `evidenceCiphertext`, createdAt	Hash and metadata plaintext; tier-1 data and evidence encrypted
IndexKey	one row: 256-bit HMAC key	Encrypted under tag `index-key`; only member roles decrypt it
DisclosureRequest	id, reportId, requester user and organisation, case reference, status, createdAt, expiresAt	Plaintext metadata
Approval	id, requestId, approver user and organisation, decision, decidedAt	Plaintext metadata
Proposal and Vote	proposal type, applicant organisation, status; voter organisation, decision, time	Plaintext metadata
AuditEvent	id, time, actor, organisation, action, object, result, previous hash, hash	Plaintext metadata

Encrypted payloads. `tier1Ciphertext` (tag `tier1`) holds the reason code and report date. `evidenceCiphertext` (tag `evidence`) holds the free-text evidence.

Keyed hash. The browser normalises an account identifier, then computes HMAC-SHA-256 with the index key using the Web Crypto API. The server only ever receives the hash, so it can match a lookup without seeing the identifier.

What the operator can and cannot see

Item	Visible to operator?
Account identifiers	No, only a keyed hash
Evidence text	No
Reason code and report date	No, encrypted under `tier1`
Reporting organisation	Yes, needed to route approvals (MVP trade-off)
Number of reports, timing, who looked up which hash	Yes
Passwords or password hashes	None exist

Item	Visible to operator?
Decryption keys	No

Known leaks, stated openly. The operator learns report counts, timing, reporting organisations and which hash each member looked up. A member who holds the index key could guess low-entropy account numbers by trial. Private set intersection is the roadmap fix.

TideCloak integration and threat model

TideCloak is the foundation, not a login box: remove it and the operator would hold the keys, so the operator-dump demo fails. Items marked VERIFY are inferred from the docs and must pass a spike before they appear in the pitch.

Need	TideCloak feature	Used in	Status
No shared password database to steal	BYOiD login, no stored credentials	F1	From docs
Evidence and index key unreadable to the host	`doEncrypt()` and `doDecrypt()` with tags and role permissions	F2, F3	`doEncrypt` and `doDecrypt` documented; cross-user decrypt is VERIFY (S2)
Forged or wrong-role requests rejected	`verifyTideCloakToken` and the Next.js middleware	All API routes	From docs
Disclosure needs two distinct organisations, with expiry	Forseti policy: explicit M-of-N approvers, distinct-organisation and no-self-approval rules, time-lock	F6	VERIFY (S4)
No admin can quietly grant themselves access	Quorum-approved role and permission changes	F5, F8	VERIFY (S5); no app-facing API found

Threat model

Attack	Expected outcome	Shown in demo
Operator dumps database and server logs	Only ciphertext, keyed hashes and metadata	Yes
Rogue admin grants themselves `vault-analyst`	No effect without a quorum	Yes
Requester approves their own disclosure	Rejected	Yes
Two users from the same organisation both approve	Counted once, request stays pending	Yes
Request with no token or the wrong role	401 or 403	Optional
Reuse of evidence access after 30 minutes	Decryption fails	Yes
Outsider brute-forces hashes from a stolen dump	Not feasible without the index key	Talking point

Out of scope, said plainly. A host that serves altered front-end code could attack the browser. A member insider with the index key can guess identifiers. Members and the Tide network can still be legally compelled; the claim is that the host has no key to hand over.

Swap test. With an ordinary identity provider and a database key, the operator holds the key. The operator-dump beat then shows plaintext. TideCloak is what makes the demo true.

Architecture, stack and API

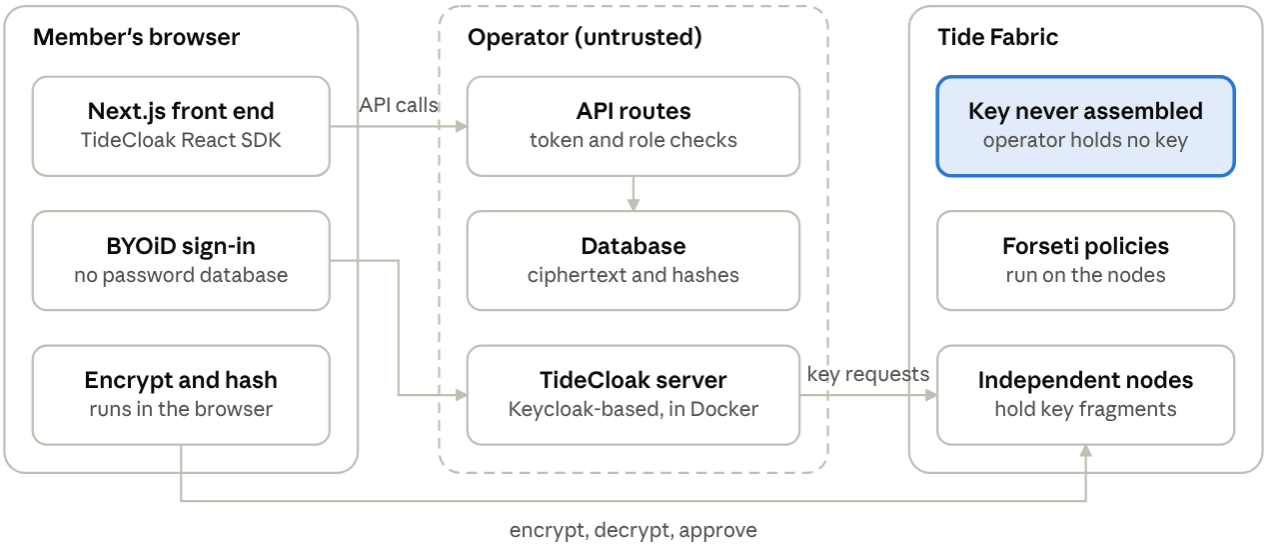
A Next.js app talks to a TideCloak server and to the Tide Fabric. The operator hosts the app, the database and the TideCloak server, but never holds a key.

Stack

- **App:** Next.js with TypeScript. Protect routes with `createTideCloakMiddleware` (Next.js 13.5 to 15) or `createTideCloakProxy` (Next.js 16), and call `verifyTideCloakToken(config, token, allowedRoles)` inside handlers.
- **Browser:** the TideCloak React SDK (`TideCloakContextProvider` , `useTideCloak()` , `doEncrypt()` , `doDecrypt()`) and the Web Crypto API for HMAC-SHA-256.

- **Identity:** TideCloak in Docker, started by the quickstart. `npm run init` in `template-ts-app` creates the `forseti-test` realm on port 8080 and writes `data/tidecloak.json`. It needs Docker, Node.js 20.9 or newer, and a Chromium-based browser or Firefox.
- **Database:** SQLite for the demo, so the operator dump is a single file.
- **Policies:** start with the Forseti default contract (role and time-lock parameters). Write a custom C# contract only if time allows.

The operator hosts the app and database but holds no key



architecture and trust boundary · 3 zones

Solid arrows are normal traffic. The long arrow under the zones is the browser's encryption, decryption and approval requests to the Fabric. The exact network path for that arrow is confirmed in spike S1.

API routes. Every route verifies the token on the server and returns 401 or 403 as in F1.

Route	Role	Purpose
`POST /api/reports`	`vault-analyst`	Store the hash, tier-1 and evidence ciphertext, and reporting organisation
`GET /api/index-key`	Member	Return the encrypted index key
`GET /api/lookup?h=HASH`	`vault-analyst`	Return matching tier-1 ciphertext rows

Route	Role	Purpose
`POST /api/disclosures`	`vault-analyst`	Create an evidence request with a case reference
`GET /api/disclosures`	Member	List my requests and those awaiting my approval
`POST /api/disclosures/:id/decision`	`vault-approver`	Approve or deny; enforces the distinct-organisation rule and logs it
`GET /api/disclosures/:id/evidence`	Requester	Return evidence ciphertext while approved and unexpired
`GET /api/proposals`, `POST /api/proposals`, `POST /api/proposals/:id/vote`	`vault-admin`	Governance, or hand off to the admin console if spike S5 falls back
`GET /api/audit`	Member	List audit events
`GET /api/operator/dump`	Demo only	Return the raw tables as the operator sees them
`POST /api/operator/attempt`	Demo only	Try the rogue-admin actions and return the outcome
`POST /api/demo/reset`	Demo only	Restore the seed data

Screens and UI requirements

Eight screens, all behind login except the first. Every page carries a visible "Synthetic data" banner and the signed-in user's organisation and role.

Screen	Who	Contents	Key states
Sign in	Anyone	BYOiD sign-in button	Failed login, not enrolled
Home	Members	Organisation, role, shortcuts, items awaiting my approval	No tasks
New report	`vault-analyst`	Account identifier, reason code, evidence text, submit	Encrypting, saved, error

Screen	Who	Contents	Key states
Lookup	`vault-analyst`	Account identifier input, result card (hit with reason code, reporting organisation, date, or no match), button to request evidence	Hit, no match, index key not decrypted
Disclosures	Analyst, approver	Tabs: My requests, Awaiting my approval. Approve and deny with reason. Evidence viewer with a visible 30-minute countdown	Pending, approved, denied, expired
Governance	`vault-admin`	Proposals, vote tally against threshold, vote buttons	Open, passed, rejected
Audit log	Members	Filterable list of events, chain check button (if F9)	Empty, filtered
Operator view	Demo only	Raw table dumps, server log, buttons for "Grant myself analyst" and "Approve my own request", outcome panel	Attempt blocked, attempt succeeded (should never happen)

UI rules. Blocked actions explain why in plain words (for example, "Needs approval from a second organisation"). Nothing sensitive appears in URLs or the browser console. A reset-demo control is available to the demo operator only.

Verification spikes (first hour)

Five questions decide which parts of the pitch are true. Each has a pass test and a fallback. At the end of the hour, record the outcome of each and change the pitch wording to match.

ID	Question	Pass test	If it fails
S1	Does TideCloak run and can four demo users sign in?	The quickstart (`forseti-crypto-quickstart` , `npm run init`) starts TideCloak on port 8080. Four users enrol through BYOiD, sign in to the Next.js app, and the server accepts their token via `verifyTideCloakToken` .	Nothing else can proceed. Escalate immediately and ask the organisers.

ID	Question	Pass test	If it fails
S2	Can a Bank B role decrypt data a Bank A user encrypted?	Bank A encrypts a test string under tag `evidence`. A Bank B user with the decrypt role reads it. A user without the role cannot.	Use one shared tag and one member role for all decryption, separate tiers in app logic, and say the tiers are enforced by the app.
S3	Does the organisation reach the token?	The token carries the user's organisation (group or attribute) and the server reads it.	Keep a server-side map from TideCloak user id to organisation.
S4	Can a policy require two approvals from distinct organisations, with expiry?	A request stays locked until two approvals from two organisations arrive, and access stops after 30 minutes. Self-approval fails.	Record approvals in the app, release access by granting a time-limited role, and label it "enforced by the app, not the Fabric".
S5	Is quorum approval of role changes usable?	An attempted role grant stays pending until a majority of admins approve, visible in the admin console or API.	Demo governance in the TideCloak admin console. If it is unavailable, use an app-level vote and label it simulated.

Time box. Give each spike no more than 15 minutes of dead-end work before switching to its fallback. The aim is a working demo with honest labels, not a perfect build.

Demo plan and success criteria

The demo runs in five minutes with four teammates playing Bank A, Bank B, Telco C and the operator. All accounts, organisations and reports are synthetic and obviously fake.

Beat	Time	Action	Expected result
1. Problem	30s	Show the 2023 figures and the National Fraud Portal. Ask what happens if no single host can be trusted with everyone's data.	Judges see the real-world problem and that the pitch complements the portal

Beat	Time	Action	Expected result
2. Report and check	60s	Bank A files a mule report. Bank B looks up the account.	Hit with reason code and reporting organisation, no evidence
3. Tier-2 disclosure	60s	Bank B requests the evidence. Bank A approves. Bank B tries to approve its own request and fails. Telco C approves.	Evidence opens with a 30-minute countdown, then expires
4. Breach theatre	60s	The operator dumps the database and logs, then tries to grant themselves a role.	Ciphertext and hashes only. The role grant stays blocked
5. Governance	45s	Members vote to admit E-wallet D.	D becomes active after two of three votes
6. Audit and close	30s	Show the audit log and name what is simulated.	Everything above appears, in order

Seed data. Three active organisations, one pending applicant, and about fifteen fake reports using clearly artificial identifiers. A reset script restores this state in under a minute.

Success criteria

- The full script runs three times in a row with no manual fixes.
- The operator view never shows a plaintext identifier, reason code or evidence.
- Every must-have and should-have acceptance criterion in the features table passes.
- Each demo claim matches the spike outcomes. Fallbacks are labelled on screen.
- A recorded backup video exists in case the network or the Fabric fails live.

How the MVP meets the five judging criteria

Criterion	How it is met
Real-world problem	Mule accounts and scam losses, with the 2023 NSRC figures and the National Fraud Portal as context
Trust, privacy, custody or authority constraint	Secrecy duty, one host seeing everyone's data, and no single party able to widen access
Core application functionality	Report, lookup, disclosure, governance and audit all work on synthetic data

Criterion	How it is met
Meaningful TideCloak integration	BYOiD, tagged encryption, token checks, policy approvals and quorum changes, each tied to an attack that fails
Working demo	The six-beat script above, rehearsed and recorded

Risks, limitations and open questions

The largest risk is that a TideCloak feature we plan to rely on does not behave as the docs suggest. The spikes exist to find out early.

Risk	Impact	Mitigation
Cross-user decrypt or policy approvals do not work as assumed	Core claims weaken	Spikes S2 and S4, with labelled fallbacks
No app-facing quorum API for role changes	Governance demo less polished	Demo in the TideCloak admin console, or label an app-level vote as simulated
TideCloak was in beta in the sources read, and the Fabric is a dependency	Live demo could fail	Recorded backup video, early end-to-end test on the venue network
Sparse documentation	Slower build	Start from the Forseti quickstart and the Next.js reference
AI-generated code logs plaintext or keeps keys in environment variables	Breaks the operator-blind claim	Review all server code and logs against the operator-view test
Overclaiming security	Loses credibility	Say "no single party can", state the known leaks, and avoid "unhackable"
Legal statements are wrong or outdated	Misleading pitch	Have the s.133 reading checked before it is shown

Assumptions

- The sources read describe TideCloak's claims as the developers' own, and they were not independently verified here.
- The 2023 scam figures are the latest ones found, and may be out of date.
- The Financial Services Act summary comes from a 2016 article.

Open questions

- What does the Challenge 2 brief require, and what is the time limit?
- Must the demo run on RMIT RACE Cloud, or may it run locally?
- How many teammates will build this, and who owns which part?
- Do telcos and e-wallets participate in the National Fraud Portal today?
- Has a lawyer or lecturer checked the secrecy-duty framing?

Build plan and task split

Five phases, each with an exit test. Durations are left open until the Challenge 2 deadline is known.

Phase	Goal	Exit test
0. Spikes	Answer S1 to S5	Outcomes recorded, pitch wording updated
1. Core	Login, encrypted report, tier-1 lookup, operator view	Features F1 to F5 pass their acceptance criteria
2. Disclosure and audit	Tier-2 approvals, expiry, audit log	F6 and F7 pass, including self-approval rejection
3. Governance and polish	Vote to admit E-wallet D, error messages, banner, reset script	F8 passes, or the fallback is labelled
4. Rehearse	Three clean runs, backup video, slides	Success criteria all met

Task split for four people

Person	Owns	Main deliverables
A: TideCloak and policy	Spikes S1, S2, S4 and S5, roles, user enrolment, policy setup	Working realm, roles, approval policy, spike report

Person	Owns	Main deliverables
B: Backend	API routes, token checks, database, audit log, seed and reset scripts	All endpoints, operator dump data, audit chain
C: Frontend	Screens, in-browser encryption and hashing, countdown, operator view	All eight screens connected to the API
D: Demo and narrative	Test data, script, slides, backup video, legal and source check, quality checks against the acceptance criteria	Rehearsed demo, claims checked against spike results

API surface (summary). Detailed routes are in the architecture section.

Sources

Pages opened while preparing the concept this specification is built from. TideCloak statements are the vendor's own claims unless stated otherwise.

- BNM: National Fraud Portal launch
- The Edge Malaysia: scam and mule account figures (BNM Annual Report 2023)
- Mondaq: A Banker's Duty of Secrecy (2016)
- Tide docs: Forseti policy engine
- Tide docs: Core concepts
- Tide docs: React SDK introduction
- Tide docs: Next.js reference
- TideCloak overview
- Forseti crypto quickstart (GitHub)
- KeyleSSH (GitHub)